

Cloud Security Risk Assessment & GRC Simulation (Azure)

Summary

This report documents the results of a cloud security risk assessment conducted on a single Azure-hosted virtual machine from a Governance, Risk, and Compliance (GRC) perspective. The purpose of the assessment is to identify critical assets, evaluate realistic threat scenarios, assess vulnerabilities, quantify risk, and recommend security controls aligned with recognized industry frameworks.

The assessment identified multiple medium to high risks, primarily related to exposed remote access, lack of multi-factor authentication, default operating system hardening, and limited centralized monitoring. While no active exploitation was observed during the assessment, these findings reflect common cloud misconfigurations that could be leveraged by attackers if left unaddressed.

Scope and Enviroment

- Single Azure Virtual Machine
- No additional cloud services or applications included
- Assessment performed from a GRC perspective

Item	Description
Cloud Provider	Microsoft Azure
Resource Group	GRC-Lab
Virtual machine Name	GRC-WIN-VM01
Operating System	Windows Server 2022 Datacenter

Cloud Security Risk Assessment & GRC Simulation (Azure)

Access Method	Remote Desktop Protocol(RDP)
Public Exposure	Yes(if Public IP Enabled)
Admin Account	azureadmin

Identify Assets, Threats, and Vulnerabilities

Asset	Threat	Vulnerability	Why It Matters
Azure VM	Brute Force Attack	RDP exposed to the internet	Easy entry point for attackers
Admin Account	Credential Theft	No MFA	Full system compromise
OS	Exploitation	Default Hardening	Common Windows Attack
Logs	Undetected	No Centralized	Delayed detection of
Azure	Misconfiguration	Single Admin	High Impact if misused

Risk Scores

Asset	Threat	Likelihood	Impact	Score	Justification
RDP	Brute Force Attack	4	4	16	Public Exposure
Admin	Credential Compromise	3	5	15	Full System
Os	Unpatched Vulnerability	3	4	12	Common attacks
Azure	Privilege Misuse	2	5	10	High Impact
Logs	Undetected Attack	3	3	9	Delayed Response

Cloud Security Risk Assessment & GRC Simulation (Azure)

Security Controls and Compliance Mapping

Risk	Control	Control Type	Framework
RDP attacks	Restricted Inbound IP Address	Preventive	CIS 4
Credential Theft	Enforce MFA	Preventive	NIST CSF PR.AC
OS Exploits	Patch Management	Corrective	CIS 7
Lack of logging	Centralized Logging	Detective	NIST CSF DE.CM
Privilege Escalation	RBAC enforcement	Preventative	CIS 5

Recommended Mitigation Actions

- Restrict RDP access via Network Security Groups (NSGs) to trusted IP ranges.
- Enable multi-factor authentication (MFA) for all administrative accounts.
- Apply regular operating system patches and updates.
- Enable Azure Monitor or Defender for centralized logging and alerts.
- Implement role-based access control (RBAC) for Azure resources.